

RECURSOS E DIRETRIZES DE SEGURANÇA DA INFORMAÇÃO DO SISTEMA GUARDIÃO

Este relatório detalha a arquitetura técnica, os controles criptográficos, a segregação de acessos e os mecanismos de proteção operantes no aplicativo, com base em boas práticas de mercado e padrões OWASP.

DADOS GERAIS DA PLATAFORMA:

- Sistema: Guardião (Controle de Acesso, Missões & Ocorrências)
- Arquitetura: Zero Trust Client-Server / PostgREST / PostgreSQL Seguro
- Aplicação: Grupo de Segurança e Defesa (GSD-SP)
- Frameworks de Referência: OWASP ASVS v4.0 / NIST SP 800-53 / CIS PostgreSQL

1. MODELO DE DEFESA EM PROFUNDIDADE & ZERO TRUST

O Sistema Guardião adota como premissa que nenhum cliente frontend é intrinsecamente confiável. Por conseguinte, todas as decisões de autorização, integridade de dados e auditoria são executadas e validadas diretamente no motor do banco de dados (Server-Side Enforcement). A plataforma opera dividida em quatro camadas estanques de segurança:

1. CAMADA DE TRANSPORTE & REDE (EDGE)

Conexões 100% criptografadas via TLS 1.3 / HTTPS forçado com cabeçalho HSTS (max-age=63072000; includeSubDomains; preload). Isolamento de conexões via WAF e mitigação de DDoS na borda.

2. CAMADA DE APLICAÇÃO & SESSÃO (WEB)

Execução sem permissão de execução arbitrária de código. Sanitização contextual anti-XSS com DOMPurify, Content Security Policy (CSP) restritiva, proteção contra clickjacking e frames.

3. CAMADA DE IDENTIDADE & ACESSO (IAM)

Identificação militar única por SARAM/CPF, autenticação protegida por Bcrypt (custo 10), suporte a biometria nativa WebAuthn/FIDO2 e proteção anti-força bruta com bloqueio temporal.

4. CAMADA DE BANCO DE DADOS & PERSISTÊNCIA

Controle de Acesso por Coluna (Column-Level Grants), Row-Level Security (RLS) multi-inquilino segregado por Organização Militar (OM) e Stored Procedures seguras (SECURITY DEFINER).

CONFORMIDADE COM NORMAS DE SEGURANÇA E CIBERDEFESA:

NORMA / REFERENCIAL	APLICAÇÃO PRÁTICA NO SISTEMA GUARDIÃO	STATUS
OWASP Top 10 (2021)	Todos os 10 vetores de vulnerabilidade mitigados (Controle de Acesso, Criptografia, XSS, Injeções).	100% ATENDIDO
NIST SP 800-63B	Gerenciamento seguro de autenticadores digitais, hashing de senhas sem texto claro e expiração mandatória.	CONFORME
CIS Benchmark PostgreSQL	Princípio do menor privilégio em roles, search_path imutável e revogação de privilégios públicos.	CONFORME
Privacidade & LGPD	Tratamento restrito a finalidades operacionais legítimas, rastreabilidade e expurgo de transitórios.	CONFORME

2. GESTÃO DE IDENTIDADE, AUTENTICAÇÃO & CONTROLE DE ACESSO (IAM)

O sistema não utiliza contas compartilhadas ou genéricas em suas atividades operacionais. Cada militar possui sua identidade unívoca atrelada ao seu SARAM, CPF e posto/graduação, com níveis de autorização estritamente delineados pela cadeia de comando militar.

A. Hashing Criptográfico Resistente (Bcrypt Blowfish)

Todas as senhas de usuários são cifradas no servidor utilizando o algoritmo Bcrypt (custo 10 com salt aleatório criptográfico). Nenhuma senha é armazenada ou trafegada em texto puro no banco de dados. O sistema possui rotina de auto-upgrade criptográfico para credenciais herdadas.

B. Autenticação Biométrica FIDO2 / WebAuthn

Integração com sensores de biometria nativos do dispositivo do militar (Touch ID, Face ID, Windows Hello e Android Biometric). Utiliza criptografia assimétrica baseada em par de chaves pública/privada armazenada no enclave de segurança de hardware (TPM / Secure Enclave).

C. Proteção Anti-Força Bruta e Rate Limiting por IP/Usuário

A tabela de auditoria login_attempts registra cada evento de autenticação. Caso sejam detectadas 5 tentativas incorretas em uma janela de 15 minutos para um mesmo usuário, a conta entra em bloqueio de segurança temporal automático, mitigando ataques de dicionário ou credential stuffing.

D. Modelo de Permissões RBAC Militar Granular

Segregação de funções em múltiplos níveis hierárquicos: Comandante, Gestor Master / OSD, Oficial de Dia, Administrador de OM, Sargento de Dia, Operador de Acesso e Sentinela. O banco bloqueia qualquer tentativa de um usuário comum elevar suas próprias prerrogativas.

3. FLUXO MILITAR DE REDEFINIÇÃO DE SENHA COM DUPLO CONTROLE

Para assegurar que nenhum militar tenha sua senha alterada de forma ilegítima, e sem depender de canais vulneráveis (como e-mails externos), o sistema adota o Procedimento Operacional Padrão de Duplo Controle via Oficial de Dia da OM:

Etapa 1: Solicitação pelo Militar

O militar informa seu SARAM na tela de login. A RPC request_password_reset registra a pendência no banco de dados e emite resposta idêntica mesmo se o SARAM não existir, neutralizando tentativas de enumeração de contas militares (OWASP ASVS).

Etapa 2: Confirmação pelo Oficial de Dia

O Oficial de Dia ou Administrador da OM visualiza o militar na lista de pendências do painel administrativo. O Oficial confirma a identidade pessoalmente ou por canal funcional seguro e clica em "Autorizar Reset (123456)".

Etapa 3: Emissão com Expiração Mandatória

A RPC admin_authorize_password_reset gera o acesso provisório padrão 123456 com hash Bcrypt e ativa os flags reset_password_at_login = true e password_status = "EXPIRED".

Etapa 4: Troca Obrigatória no Primeiro Acesso

Ao logar com a provisória, a RPC secure_login identifica a expiração compulsória e redireciona o militar para tela exclusiva de redefinição. A nova senha definitiva (mín. 8 caracteres) é gravada e a conta é ativada.

4. HARDENING DO BANCO DE DADOS & SEGURANÇA EM NÍVEL DE TABELA (RLS/CLS)

A camada de persistência PostgreSQL é o pilar central de segurança do Guardião. Nenhuma tabela é exposta de maneira aberta ou descuidada para conexões públicas, implementando segregação estrita por patente, função e Organização Militar:

Column-Level Security (Revogação Estrita de SELECT/UPDATE em password)

A coluna password da tabela public.users possui privilégio de SELECT e UPDATE totalmente REVOGADO para as roles anon e authenticated. Nenhum invasor ou script no navegador consegue ler hashes de senhas de outros usuários, tornando inviável a extração de senhas via API REST.

Isolamento Multi-Inquilino (Row-Level Security por om_id)

Todas as tabelas de missões, controle de efetivo, viaturas, ocorrências e cadastros possuem políticas de RLS ativas. O Oficial de Dia e os administradores de uma OM só possuem visibilidade e prerrogativa de intervenção sobre os registros de sua própria Unidade Militar.

Search Path Fixo e Imutável em Funções SECURITY DEFINER

Todas as Stored Procedures e RPCs administrativas operam com "SET search_path = public, extensions, pg_temp;". Isso impede vetores de sequestro de schema (Schema Hijacking), onde tabelas maliciosas poderiam ser executadas no contexto de privilégios elevados.

Proteção contra Alteração Arbitrária de Papéis e Permissões

Tentativas de modificar as colunas role, access_level ou custom_permissions diretamente pelo cliente são bloqueadas no motor do PostgreSQL. Somente as RPCs seguras admin_save_user_permissions e admin_create_user_secure validam a autoridade do solicitante.

5. PROTEÇÃO DE OBJETOS EM NUVEM (STORAGE) & ANEXOS OPERACIONAIS

Restrição de Tipos de Arquivo (MIME)

O envio de anexos (como CNH, CRLV, fotos de avarias em viaturas e documentos de missão) aceita exclusivamente imagens (PNG, JPEG, WEBP) e documentos PDF. Scripts e executáveis são rejeitados no gateway.

Limite Físico de Quota (5 MB)

Cada upload possui limite máximo de 5 megabytes por arquivo, prevenindo ataques de negação de serviço (DoS) por esgotamento de banda ou saturação de armazenamento.

Revogação de Deleção Pública Anônima

Políticas que permitiam deleção indiscriminada em buckets foram expressamente revogadas. Apenas administradores e o próprio proprietário do registro podem gerenciar seus arquivos.

Assinatura de URLs e Controle de Acesso

Documentos sensíveis de efetivo e relatórios de ocorrência operam com tokens de expiração temporária para visualização autenticada.

6. SEGURANÇA EM APLICAÇÃO WEB, CABEÇALHOS HTTP & DEFESAS ATIVAS

Sanitização Anti-XSS (DOMPurify)

Todo conteúdo gerado pelo usuário (relatos de ocorrência, termos de inspeção, históricos) passa por purificação rigorosa contra Cross-Site Scripting (XSS) com biblioteca DOMPurify.

Cabeçalhos HTTP Hardened

Configuração estrita no servidor: X-Frame-Options: DENY (anti-clickjacking), X-Content-Type-Options: nosniff, Strict-Transport-Security e Permissions-Policy.

Prevenção de SQL Injection

O cliente web não interpola strings SQL. Todas as consultas trafegam como chamadas parametrizadas via PostgREST ou RPCs compiladas no PostgreSQL.

Zero CVEs em Dependências

Varredura contínua de pacotes npm audit. Todas as 35 bibliotecas do ecossistema estão em versões estáveis e sem vulnerabilidades conhecidas reportadas no NVD.

7. RASTREABILIDADE, NÃO-REPÚDIO & LOGS DE AUDITORIA OPERACIONAL

QR Codes Dinâmicos & Criptografados

Identificação e crachás digitais geram tokens assinados que validam autenticidade nos postos de sentinela, impossibilitando clonagem de passes de serviço.

Carimbo de Data/Hora & Assinatura Digital

Despachos operacionais, autorizações de missão e aprovações de estacionamento gravam a identidade do militar responsável com timestamp UTC auditável.

Checklist de Viaturas SAP-03 Auditado

Registro gráfico de danos, nível de combustível e avarias com confirmação de entrega e recebimento por militares em serviço.

Histórico Imutável de Ocorrências

Cada alteração de status de uma ocorrência policial ou de segurança militar é anexada ao histórico temporal do caso, garantindo a cadeia de custódia da informação.

CONCLUSÃO TÉCNICA: ARQUITETURA SEGURA E RESILIENTE

O aplicativo dispõe de controles modernos de segurança da informação e defesa em profundidade, provendo confidencialidade, integridade e rastreabilidade para as rotinas do Grupo de Segurança e Defesa (GSD-SP).